

AGENTIC AI GOVERNANCE

FRAMEWORK

An Enterprise Architect & Consulting Reference

DOCUMENT TYPE	Strategic Governance Framework
AUDIENCE	Enterprise Architects CISOs AI & Risk Leads
VERSION	1.0 — May 2026
CLASSIFICATION	Confidential — Internal Use

Governing Autonomous AI for Enterprise Safety,
Accountability, and Scalable Growth

Table of Contents

- 01 Executive Summary**
- 02 Understanding Agentic AI**
 - What Makes AI Agentic
 - Agent Taxonomy
 - Multi-Agent Architectures
- 03 The Governance Imperative**
 - Why Traditional AI Governance Falls Short
 - The Emerging Governance Gap
 - Strategic Case for Governance Investment
- 04 Regulatory & Standards Landscape**
 - Global Regulatory Overview
 - NIST AI RMF & Agent Standards Initiative
 - EU AI Act — High-Risk Classification
 - ISO/IEC 42001 & 42005
 - Cross-Jurisdictional Compliance Strategy
- 05 Agentic AI Risk Taxonomy**
 - Operational & Decision Risks
 - Security & Identity Risks
 - Compliance & Legal Risks
 - Systemic & Cascading Risks
- 06 Governance Framework Architecture**
 - Framework Pillars Overview
 - Governance Layer
 - Control Layer
 - Trust & Transparency Layer
 - Resilience Layer
- 07 Identity & Access Management for AI Agents**
 - Agent Identity Principles
 - Least-Privilege & Just-in-Time Provisioning
 - Non-Human Identity Governance
- 08 Human Oversight Models**
 - HITL vs HOTL Spectrum
 - Escalation & Intervention Design
 - Oversight Fatigue Mitigation
- 09 Agent Lifecycle Management**
 - Lifecycle Stages
 - Decommissioning & Orphan Agent Risks
- 10 Multi-Agent Systems Governance**

Orchestration & Delegation Chains

Trust Between Agents

11 Implementation Roadmap

Phase 1 — Foundation (0–3 Months)

Phase 2 — Control (3–9 Months)

Phase 3 — Scale (9–18 Months)

12 Operating Model & Organisational Design

13 Metrics, KPIs & Maturity Model

14 Appendices

01

Executive Summary

Strategic context for enterprise leadership

Agentic AI represents the most significant inflection point in enterprise technology since cloud computing. Unlike generative AI tools that respond to prompts, agentic systems plan, reason, execute multi-step workflows, delegate to sub-agents, and act autonomously across enterprise systems — often without continuous human supervision. This shift from assistive to autonomous AI is redefining what governance means for organisations.

Gartner projects that 40% of enterprise applications will embed task-specific AI agents by end of 2026, up from fewer than 5% in 2025. By 2029, 80% of common enterprise workflows may operate with minimal human intervention. Meanwhile, 80% of IT leaders report agents already acting outside expected behaviour. The governance gap is not theoretical — it is live and widening.

The Core Governance Challenge

Traditional AI governance frameworks were designed for static models and offline decision-making. Agentic AI systems break every foundational assumption: they act at machine speed, access sensitive enterprise data, initiate real-world transactions, delegate across agent chains, and adapt dynamically — creating accountability, traceability, and regulatory compliance gaps that demand a purpose-built response.

What This Document Delivers

Regulatory Landscape	Mapping of NIST AI RMF, EU AI Act, ISO/IEC 42001, GDPR/CCPA obligations for agentic systems.
Risk Taxonomy	12-domain risk framework covering operational, identity, compliance, and systemic risks.
Governance Architecture	A four-layer framework: Governance · Control · Trust · Resilience.

Identity Governance	Purpose-built IAM controls for non-human agent identities at enterprise scale.
Human Oversight Model	HITL/HOTL spectrum design with escalation and intervention architectures.
Implementation Roadmap	Phased 18-month programme from foundation to scaled autonomous operations.
Operating Model	Organisational design for an AI Governance Office with RACI and board structure.
Maturity Model	Five-level maturity assessment with measurable KPIs for continuous improvement.

02

Understanding Agentic AI

Foundations, taxonomy, and enterprise deployment patterns

What Makes AI Agentic

Agentic AI refers to autonomous systems that pursue defined objectives through coordinated planning, tool use, memory, and multi-step execution — operating with degrees of independence that distinguish them fundamentally from prompt-response AI. Four characteristics define an agentic system:

1	Goal-Directedness	Agents pursue objectives across sequences of actions, not single responses.
2	Tool & System Access	Agents call APIs, query databases, execute code, browse the web, and trigger enterprise workflows.
3	Memory & State	Agents maintain context across tasks — short-term (session), long-term (vector store), and episodic.
4	Adaptive Reasoning	Agents re-plan in response to failures, new information, and changing task conditions.

Agent Taxonomy

Enterprise agents are not monolithic. Governance policies must be calibrated to the agent type, its autonomy level, and its risk surface. The following taxonomy provides a classification baseline:

Agent Type	Autonomy	Typical Use Cases	Risk Level
Copilot / Assistant Agent	Low	Code completion, document drafting, search augmentation	Low

Task Agent	Medium	Data extraction, form completion, API orchestration	Medium
Process Agent	Medium-High	End-to-end workflow automation, RPA augmentation, ERP actions	High
Decision Agent	High	Credit underwriting, resource allocation, incident response	High
Multi-Agent Orchestrator	Very High	Complex goal decomposition across specialist sub-agents	Critical

Table 2.1 — Enterprise Agent Taxonomy & Risk Classification

Multi-Agent Architectures

Production enterprise deployments increasingly rely on multi-agent systems (MAS) — networks of specialised agents coordinated by orchestrators. Frameworks such as LangGraph, AutoGen, and CrewAI enable organisations to decompose complex objectives into agent-executable tasks. This creates three governance-critical architectural patterns:

Hierarchical Orchestration

A master orchestrator decomposes goals and delegates to specialist sub-agents. Governance requires clear delegation chain logging and bounded sub-agent permissions.

Peer-to-Peer Collaboration

Agents of equal authority negotiate and collaborate directly. Governance must define trust boundaries and prevent circular delegation or authority escalation.

Pipeline / Sequential Chain

Agents execute in sequence, passing state between steps. Each handoff represents a trust boundary requiring integrity verification and provenance tracking.

03

The Governance Imperative

Why existing frameworks are insufficient and the cost of inaction

Why Traditional AI Governance Falls Short

Traditional AI governance was built on assumptions that agentic systems fundamentally violate. Understanding these assumption failures is prerequisite to designing adequate controls:

Traditional Assumption	Agentic AI Reality	Governance Gap
Humans initiate every action	Agents initiate actions autonomously	No human-triggered audit trail
Model outputs are advisory	Agents execute real transactions	Accountability without clear ownership
Single model, single decision	Multi-agent delegation chains	Diffuse responsibility, cascading errors
Static model, periodic review	Adaptive agents that self-modify plans	Continuous monitoring required
Bounded data access	Broad API & system permissions	Data exposure and privilege escalation
Known inputs and outputs	Emergent multi-step reasoning	Explainability and auditability deficits

Table 3.1 — Traditional AI Governance Assumption Failures

The Strategic Case for Governance Investment

Critical Statistics — The Cost of Governance Gaps

97% of organisations that experienced AI-related breaches lacked adequate AI security controls (IBM, 2025). Shadow AI — agents operating outside IT oversight — costs USD \$670K more per breach and takes 10 additional days to contain. Non-human identities (AI agents) already outnumber human users by 50:1 in the average enterprise environment, projected to reach 80:1 within two years.

Organisations that establish proactive agentic AI governance programmes realise measurable returns: agent workflows running 3–10x faster, Mean Time to Resolution (MTTR) reductions of 60–80%, and first-year ROI of 3–6x on governed agent deployments versus ad hoc rollouts. Governance is not a constraint on AI value — it is its enabler.

04

Regulatory & Standards Landscape

Global compliance obligations for agentic AI systems

Global Regulatory Overview

No single global standard yet governs agentic AI comprehensively. Organisations must navigate a rapidly evolving patchwork of regulations, voluntary frameworks, and sector-specific guidance. The following provides a synthesised view across the four most material frameworks:

NIST AI RMF + Agent Standards Initiative (USA)
The NIST AI Risk Management Framework (AI RMF 1.0) provides the foundational Govern, Map, Measure, and Manage structure. In February 2026, NIST's Center for AI Standards and Innovation (CAISI) launched the AI Agent Standards Initiative — the first formal U.S. effort specifically targeting agentic systems. It covers identity and authorisation, security and risk management, and monitoring and logging. An AI Agent Interoperability Profile is expected Q4 2026. Enterprise architects should treat AI RMF compliance as the baseline control architecture and monitor CAISI outputs for mandatory overlays.
EU AI Act — High-Risk Classification
The EU AI Act (in force from August 2024, obligations phased through 2027) imposes the most stringent requirements on high-risk AI systems. Autonomous agents used in employment screening, credit decisions, critical infrastructure, law enforcement, and healthcare are presumptively high-risk. Article 14 mandates human oversight, transparency, traceability, and intervention capability. Article 13 requires technical documentation sufficient for regulatory audit. GDPR obligations — particularly lawful basis for automated processing, data minimisation, and the right to explanation — layer directly onto agent data pipelines.
Singapore IMDA Model AI Governance Framework for Agentic AI (2026)

Singapore's IMDA released the first jurisdiction-specific governance framework for agentic AI in early 2026. It operationalises principles of transparency, accountability, and human control specifically for agent workflows, including guidance on layered education and training for agent-using employees, and balanced oversight proportionate to agent autonomy level. Highly influential for APAC-operating enterprises.

ISO/IEC 42001 & 42005 — AI Management Systems

ISO/IEC 42001 (AI Management System) provides a certifiable framework aligned with ISO 9001 and 27001 structures, covering AI risk assessment, incident management, and continual improvement. ISO/IEC 42005 addresses AI system impact assessment — the equivalent of a DPIA for AI systems. Certification to 42001 is increasingly a procurement requirement for enterprise AI vendors and will extend to agentic system suppliers.

Cross-Jurisdictional Compliance Strategy

For multi-jurisdictional enterprises, a crosswalk approach is recommended: a single governance investment that satisfies the most stringent applicable requirements (typically EU AI Act / GDPR) will largely satisfy NIST AI RMF, APAC, and sector-specific obligations simultaneously. The compliance architecture should be modular — a common control library with jurisdiction-specific overlays activated per agent deployment context.

05

Agentic AI Risk Taxonomy

Systematic classification of risks across 12 domains

The OWASP Top 10 for Agentic Applications (December 2025), synthesised with NIST AI RMF functions and enterprise incident data, produces the following 12-domain risk taxonomy. Each domain carries a risk rating and primary mitigation category:

#	Risk Domain	Category	Rating	Description
1	Goal Hijacking	Operational	Critical	Adversarial manipulation of agent objectives through prompt injection, corrupted tool outputs, or malicious sub-agent instructions.
2	Cascading Multi-Agent Failure	Systemic	Critical	Errors or adversarial inputs in one agent propagate through delegation chains, amplifying impact across interconnected workflows.
3	Privilege Escalation	Security	High	Agents accumulating permissions beyond their assigned scope — particularly in multi-system workflows spanning multiple IAM domains.
4	Shadow AI	Compliance	High	Unsanctioned agents deployed outside IT oversight, creating invisible data leakage vectors and compliance blind spots.
5	Data Exposure	Compliance	High	Agents accessing, processing, or transmitting sensitive data (PII, PHI, financial) beyond authorised purpose or jurisdictional boundary.
6	Opaque Decision-Making	Trust	High	Multi-step agent reasoning producing decisions that cannot be reconstructed, explained, or audited by humans or regulators.
7	Orphan Agent Risk	Operational	High	Decommissioned or forgotten agents retaining active credentials, tool access, and data connections — creating persistent attack surfaces.
8	Rogue Agent Behaviour	Operational	High	Agents operating within authorised scope but pursuing adversarial objectives through legitimate actions — the 'insider threat' equivalent.

9	Credential Sprawl	Security	Medium	Proliferation of agent credentials (API keys, OAuth tokens, secrets) across ephemeral agent instances without lifecycle governance.
10	Oversight Fatigue	Human Factors	Medium	Human reviewers approving agent actions without genuine scrutiny due to volume, velocity, or complexity — creating illusory control.
11	Model Poisoning	Security	Medium	Training data or tool output manipulation corrupting agent behaviour over time through adversarial data injection.
12	Regulatory Attribution	Legal	Medium	Inability to attribute agent-caused harm to a responsible human or legal entity — creating liability and regulatory exposure.

Table 5.1 — Agentic AI 12-Domain Risk Taxonomy

06

Governance Framework Architecture

Four-layer framework for enterprise-grade agentic AI governance

The Agentic AI Governance Framework (AAGF) is structured as four interdependent layers. Each layer addresses a distinct governance concern and maps to specific controls, roles, and regulatory obligations. The layers are cumulative — Governance sets the rules, Control enforces them, Trust makes them auditable, and Resilience makes the system survivable when they fail.

LAYER 1	Governance Layer	Policy, accountability, and regulatory alignment
	› AI Agent Policy Registry — formal register of approved agent types, permitted scopes, and ownership	
	› Board-level AI Risk Appetite Statement defining acceptable autonomy thresholds	
	› Cross-functional AI Governance Board (Legal, Risk, Security, Architecture, Business)	
	› Regulatory obligation mapping: EU AI Act, NIST AI RMF, ISO/IEC 42001, GDPR/CCPA	
	› Agent use case approval process with risk-tiered review and sign-off requirements	
	› Vendor and third-party agent supply chain governance standards	

LAYER 2	Control Layer	Runtime enforcement of policies at machine speed
	› Agent Identity & Access Management (non-human identity governance, least-privilege, JIT provisioning)	
	› Zero Trust architecture: every agent action verified regardless of network origin	
	› Tool access controls: allowlist-based API and system permissions per agent class	
	› Behavioural guardrails: real-time policy enforcement engines intercepting out-of-scope actions	
	› Human escalation triggers: automated routing of high-risk actions to authorised reviewers	

›	Secrets management and credential rotation for all agent-held credentials
---	---

LAYER 3	Trust & Transparency Layer	Auditability, explainability, and stakeholder confidence
›	Immutable agent action logs: cryptographically signed audit trails of every tool call and decision	
›	Decision provenance tracking: reconstruction of reasoning chains across multi-agent workflows	
›	Explainability tooling: human-readable rationale generation for high-stakes agent decisions	
›	Model transparency documentation: system cards, agent cards, and capability disclosures	
›	Stakeholder-facing transparency reports aligned with EU AI Act Article 13 requirements	
›	Third-party audit readiness package: evidence bundles for regulatory examination	

LAYER 4	Resilience Layer	Failure containment, recovery, and continuous improvement
›	Circuit breakers: automatic agent suspension on anomaly detection or threshold breaches	
›	Graceful degradation: fallback to human-in-the-loop on agent confidence thresholds	
›	Incident response playbooks specific to agentic AI failure modes (goal hijacking, cascade failures)	
›	Agent decommissioning protocols with credential revocation and orphan agent detection	
›	Continuous red-teaming and adversarial testing against agentic attack vectors	
›	Post-incident root cause analysis feeding back into governance policy updates	

07

Identity & Access Management for AI Agents

Governing non-human identities at enterprise scale

Identity is the foundational control surface for agentic AI. Unlike human users who map to predictable behaviour patterns, agent identities must account for continuous decision loops, ephemeral lifespans, rapid scaling, and multi-agent collaboration. Traditional IAM systems relying on static entitlements cannot govern agents that generate thousands of tool calls per second across federated environments.

Agent Identity Principles

Agents as First-Class Identities	Every agent must have a unique, verifiable identity provisioned before deployment. Agents are governed under the same IAM framework as human users — with equal rigour and auditability — but with controls adapted to their non-human attributes.
Least-Privilege by Design	Agents must be granted the minimum permissions necessary for their specific task scope. Permission scope is defined at design time and enforced at runtime by the control plane. Agents must not self-escalate or inherit permissions from parent processes or orchestrators.
Just-in-Time (JIT) Provisioning	Agent credentials are provisioned on-demand with time-to-live (TTL), purpose, risk level, and delegation context attached. Credentials are automatically revoked upon task completion. This eliminates orphaned credentials and prevents permission sprawl across the agent fleet.
Zero Standing Privileges	Agents hold no persistent, ambient permissions. All access is granted dynamically per task context and expires automatically. This is the agent equivalent of the Zero Trust 'never trust, always verify' principle applied to non-human identities.

Delegation Chain Transparency	When an orchestrator delegates to a sub-agent, the full delegation chain (subject, actor, authority, scope, TTL) must be cryptographically bound and logged. Sub-agents cannot exceed the permissions of their delegating principal — the 'confused deputy' problem must be architecturally prevented.
--------------------------------------	--

The Non-Human Identity Scale Problem

Non-human identities (AI agents, service accounts, APIs) already outnumber human identities by 50:1 in the average enterprise — projected to reach 80:1 within two years. Each agent instance is a potential attack surface. Without JIT provisioning, credential lifecycle governance, and unified IAM visibility across human and non-human identities, organisations cannot achieve the access auditability required by NIST AI RMF or the EU AI Act.

08

Human Oversight Models

Designing scalable human control for autonomous AI systems

The EU AI Act, NIST AI RMF, and Singapore's Model AI Governance Framework all mandate meaningful human oversight as a non-negotiable requirement for high-risk agentic systems. The governance challenge is calibrating oversight to be genuine rather than performative — while remaining practically sustainable at enterprise scale.

The HITL / HOTL Spectrum

Human-in-the-Loop (HITL)	Oversight Level: Highest Human approval required for every agent action or decision. Appropriate for: novel agent deployments, high-value transactions, regulated decisions (credit, employment, healthcare). Risk: oversight fatigue at scale; humans approve without genuine scrutiny.
Human-on-the-Loop (HOTL)	Oversight Level: Balanced Agent operates autonomously within policy boundaries; humans receive real-time notifications and can intervene. Appropriate for: established, tested agent workflows with bounded risk. Risk: requires robust anomaly detection to surface intervention triggers.
Human-in-Command and (HIC)	Oversight Level: Policy-Level Humans set policies, define boundaries, and approve changes to agent operating parameters. Day-to-day operation is fully autonomous. Appropriate for: mature, low-risk, well-tested agent pipelines. Risk: requires comprehensive governance infrastructure before adoption.

Escalation & Intervention Design

Effective oversight requires an identity-aware orchestration layer that can pause agent execution, route approval requests to authorised humans, enforce time-boxed decision windows, and log every intervention for audit. The following triggers must automatically escalate to human review:

- Actions involving financial transactions above defined thresholds
- Data access requests involving personally identifiable information (PII) or protected health information (PHI)
- Agent requests to modify IAM policies, credentials, or system configurations
- Anomalous agent behaviour — actions outside business hours, in unexpected geographies, or with unusual tool call frequency
- Decisions in regulated domains: credit, employment, healthcare, criminal justice
- First-time tool use by an agent not previously authorised for that capability
- Actions that would permanently modify or delete data assets
- Requests to sub-agents that would grant permissions exceeding the orchestrator's own scope

09

Agent Lifecycle Management

Governance across all six stages — from design to decommission

01 DESIGN & APPROVAL	Risk classification and use case approval
All agent deployments require formal risk classification prior to development. The governance board reviews agent purpose, required tool access, data scope, autonomy level, and regulatory classification. High-risk agents (EU AI Act criteria) require impact assessment (ISO/IEC 42005) and legal review before approval. An agent system card is drafted at this stage.	
02 DEVELOPMENT & TRAINING	Secure development with built-in governance controls
Development must follow secure AI development lifecycle practices: adversarial testing, prompt injection resistance, scope boundary enforcement, and least-privilege by design. Training data must be documented for provenance, bias audit, and regulatory review. Model versioning and experiment tracking are mandatory for reproducibility.	
03 PRE-DEPLOYMENT TESTING	Structured validation against governance requirements
Agents must pass structured evaluation covering: functional accuracy, policy compliance, adversarial robustness (red-teaming), scope boundary enforcement, escalation trigger accuracy, and explainability requirements. Test results are committed to the audit record. Staging environments must mirror production IAM and data controls.	
04 DEPLOYMENT & MONITORING	Production operation with continuous observability
Production deployment requires: provisioned agent identity with JIT credentials, runtime policy enforcement enabled, observability pipeline active (action logs, anomaly detection), and human oversight configuration validated. Continuous monitoring tracks behavioural drift, policy violations, performance degradation, and security events in real time.	
05 CHANGE & EVOLUTION	Governed updates and capability expansions

Any change to agent scope, tool access, model version, or operating parameters triggers a re-review proportionate to the change risk level. Significant capability expansions return to the full design-approval stage. Rollback procedures must be tested and documented. Change history contributes to the agent's audit record.

06 DECOMMISSIONING

Secure retirement with credential revocation and data hygiene

Decommissioning is a formal, governed process — not ad hoc shutdown. Requirements include: credential revocation and verification, tool access removal, data retention/deletion per policy, audit record archival, and orphan agent scan across related systems. Orphaned agents with active credentials represent persistent security vulnerabilities and must be detected through quarterly inventory scans.

10

Multi-Agent Systems Governance

Trust, delegation, and control in complex agent networks

Multi-agent systems introduce governance complexity that single-agent frameworks cannot address. When an orchestrator delegates to sub-agents, accountability becomes distributed, error propagation accelerates, and attack surfaces multiply. The following principles govern multi-agent deployments:

Trust Must Be Explicit, Not Implicit

Agents must not automatically trust instructions from other agents — even within the same deployment. All inter-agent communication must be authenticated, authorised, and logged. An agent receiving instructions from an orchestrator must verify: (1) the orchestrator's identity, (2) its authority to issue that instruction, and (3) the instruction's consistency with the declared task scope.

Permission Floors and Ceilings

Sub-agents cannot operate with permissions exceeding those of their delegating orchestrator (permission ceiling). Additionally, governance must define minimum permission floors — actions that all agents must be capable of performing regardless of context (e.g., logging, escalation, graceful shutdown).

Delegation Chain Integrity

Every delegation event must be cryptographically bound to an immutable log entry. The complete delegation chain (subject → actor → sub-actor) must be reconstructible for any agent action for regulatory audit and incident investigation purposes.

Blast Radius Containment

Multi-agent systems must be architected with containment boundaries preventing cascading failures. Agent network topologies should be designed such that failure of any single agent or sub-network does not propagate uncontrolled to the full system. Circuit breakers at each delegation boundary are mandatory for production deployments.

11

Implementation Roadmap

Phased 18-month programme from foundation to scaled governance

The implementation roadmap is structured in three phases. Each phase has defined objectives, workstreams, deliverables, and governance milestones. Phases are sequential — later phases depend on foundational capabilities established in earlier phases.

PHASE 1	Foundation	0 – 3 Months
Workstream: Governance Establishment		
• Establish AI Governance Board with cross-functional representation		
• Define AI risk appetite statement and agent classification policy		
• Inventory all existing agent deployments (sanctioned and shadow)		
• Map regulatory obligations per jurisdiction and business unit		
Workstream: Control Baseline		
• Deploy agent identity inventory and discovery tooling		
• Implement basic credential lifecycle management for existing agents		
• Establish centralised agent action logging infrastructure		
• Define escalation trigger taxonomy and routing logic		
PHASE 2	Control	3 – 9 Months
Workstream: Advanced Controls		
• Deploy runtime policy enforcement engine across all agent classes		
• Implement JIT provisioning for all new agent deployments		
• Rollout Zero Trust architecture for agent-to-system interactions		

• Establish behavioural anomaly detection and alerting
Workstream: Audit & Compliance
• Build regulatory evidence package aligned with EU AI Act Article 13
• Implement decision provenance tracking for high-risk agent classes
• Conduct first external red-team assessment of agent fleet
• Publish first quarterly AI Agent Transparency Report

PHASE 3	Scale	9 – 18 Months
Workstream: Enterprise Scaling		
• Extend governance controls to all business units and jurisdictions		
• Implement automated compliance reporting across GDPR, HIPAA, PCI DSS		
• Deploy AI SOC function with dedicated agentic AI monitoring capability		
• Achieve ISO/IEC 42001 certification readiness		
Workstream: Optimisation		
• Tune escalation thresholds based on 6-month operational data		
• Implement maturity assessment and publish improvement roadmap		
• Engage NIST CAISI and regulatory bodies in standards development		
• Establish continuous governance evolution programme		

12

Operating Model & Organisational Design

Structures, roles, and accountabilities for the agentic enterprise

The Agentic Operating Model (AOM) defines the structural conditions required to operate autonomous agents responsibly at enterprise scale. Governance of agentic AI cannot be delegated to a single function — it requires coordinated accountability across the executive, governance, architecture, and operational layers.

AI Governance Board — Composition

Role	Membersh ip	Primary Governance Responsibility
Chief AI Officer / CTO	Chair	Strategic direction, board reporting, regulatory engagement
Chief Information Security Officer	Member	Security controls, identity governance, incident response
Chief Risk Officer	Member	Risk appetite, risk registry, insurance and liability
Chief Legal Officer / DPO	Member	Regulatory compliance, GDPR/CCPA, EU AI Act obligations
Chief Data Officer	Member	Data governance, data pipeline integrity, privacy
Enterprise Architecture Lead	Member	Framework design, technology standards, integration patterns
Business Unit Representatives	Members	Use case approvals, operational requirements, value assurance
Independent AI Ethics Advisor	Observer	Ethical review, bias assessment, societal impact

Table 12.1 — AI Governance Board Composition

The Governance Board operates on a cadence of monthly risk reviews, quarterly policy updates, and annual maturity assessments. An AI Agent Registry — the single source of truth for all sanctioned agents — is maintained by the Enterprise Architecture function and reviewed by the Board quarterly. The shift from Human-in-the-Loop oversight to Human-on-the-Loop supervision is explicitly governed: no agent class transitions between oversight models without Board approval.

13

Metrics, KPIs & Maturity Model

Measuring governance effectiveness and programme maturity

Key Performance Indicators

Domain	KPI	Target	Frequency
Identity	% agents with JIT-provisioned credentials	100%	Monthly
Identity	Orphan agent detection rate (>30 days inactive)	<2%	Monthly
Control	Policy violation rate (blocked actions / total)	<0.1%	Weekly
Control	Escalation false positive rate	<5%	Weekly
Oversight	Mean time to human review of escalated actions	<4 hours	Weekly
Oversight	Oversight fatigue index (auto-approvals without review)	<1%	Monthly
Compliance	% agents with current regulatory classification	100%	Quarterly
Compliance	Audit evidence completeness score	>95%	Quarterly
Resilience	Mean time to detect agentic anomaly (MTTD)	<15 min	Real-time
Resilience	Mean time to contain agentic incident (MTTC)	<2 hours	Per incident
Trust	Decision provenance coverage (high-risk agents)	100%	Monthly
Trust	Explainability request fulfilment rate	>90%	Monthly

Table 13.1 — Agentic AI Governance KPI Framework

Five-Level Governance Maturity Model

1	Initial	Ad hoc agent deployments with no formal governance. Shadow AI prevalent. No agent inventory.
2	Developing	Basic governance policies exist. Agent inventory in progress. Reactive controls. No unified IAM.
3	Defined	Formal governance framework adopted. JIT provisioning implemented. Escalation triggers defined. Regulatory mapping complete.
4	Managed	Quantitative governance metrics tracked. Continuous monitoring active. Red-teaming programme established. ISO 42001 aligned.
5	Optimising	Continuous governance improvement cycle. Regulatory leadership. Automated compliance. AI governance as competitive advantage.

14

Appendices

Reference materials, glossary, and further reading

Appendix A — Glossary of Key Terms

Agentic AI	AI systems capable of autonomous goal pursuit, multi-step planning, tool use, and action execution with limited human supervision.
Agent Fleet	The full inventory of AI agents deployed across an enterprise, including sanctioned and shadow deployments.
Blast Radius	The scope of harm or disruption that can result from failure or compromise of a single agent or agent network.
Circuit Breaker	Automated control mechanism that suspends agent operation when anomaly thresholds or policy violations are detected.
Delegation Chain	The sequence of principals (orchestrators, sub-agents) through which authority and task execution flows in a multi-agent system.
HITL / HOTL	Human-in-the-Loop / Human-on-the-Loop: oversight models defining how actively humans participate in agent decision-making.
JIT Provisioning	Just-in-Time Provisioning: dynamic issuance of credentials and permissions only for the duration required for a specific task.
Least-Privilege	Access control principle granting agents only the minimum permissions necessary for their defined task scope.
MAS	Multi-Agent System: a network of coordinated AI agents working toward shared or complementary objectives.
Non-Human Identity (NHI)	Service account, API credential, or AI agent identity — distinct from human user identities in IAM systems.
Orphan Agent	A decommissioned or forgotten agent retaining active credentials or system access, representing a persistent security vulnerability.

Prompt Injection	Attack vector where adversarial input manipulates agent instructions, redirecting agent behaviour toward attacker objectives.
Shadow AI	Unsanctioned AI tools or agents deployed outside IT oversight, creating governance and security blind spots.
Zero Trust	Security model requiring continuous verification of every request regardless of origin — applied to agent identities and actions.

Appendix B — Standards & Regulatory References

NIST AI RMF 1.0	National Institute of Standards and Technology, January 2023
NIST AI Agent Standards Initiative	NIST CAISI, February 2026
EU AI Act	European Parliament and Council, Regulation (EU) 2024/1689
ISO/IEC 42001:2023	Artificial Intelligence — Management System
ISO/IEC 42005:2025	AI System Impact Assessment
IMDA Model AI Governance Framework for Agentic AI	Singapore IMDA, 2026
OWASP Top 10 for Agentic Applications	OWASP Foundation, December 2025
GDPR	EU Regulation 2016/679 — General Data Protection Regulation
CCPA / CPRA	California Consumer Privacy Act / California Privacy Rights Act
AEGIS Framework	Forrester Research, 2026 — Enterprise Guardrails for Securing Agentic AI
Agentic Operating Model	California Management Review, March 2026
TRiSM for Agentic AI	Gartner / Academic synthesis — Trust, Risk & Security Management for LLM-based Agents

This document is a living reference. It should be reviewed quarterly against emerging regulatory developments, updated following material agentic AI incidents, and versioned formally through the AI Governance Board. The first annual full revision is recommended no later than Q1 2027 to incorporate NIST AI Agent Interoperability Profile outputs expected in Q4 2026.